SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Code of Conduct:

I D K Sumalatha(192424023) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

D K Sumalatha

Scenario-Based Assessment

Q1. Passive Security Assessment / Footprinting (15 Marks)

Scenario: A cybersecurity consultant must collect publicly available information about ABC Technologies without directly interacting with the company's servers.

1. Domain registration details – WHOIS

Tool: whois (or a reputable public WHOIS/RDAP lookup service). It can show the registrar, registration and expiry dates, domain status, and authoritative name servers. Registrant details may be hidden by privacy protection.

Example command (replace the example domain with the authorized target domain):

whois example.com

Competitive-intelligence value: registration dates and name-server information can help establish the domain's history and identify public DNS infrastructure. These details should be treated as clues, not proof of ownership or security weakness.

2. Public employee email addresses – search engines and theHarvester

Tools: search engines and theHarvester. These can locate email addresses already published on websites, public documents, or other indexed sources. Use only information relevant to the approved assessment.

Example command:

theHarvester -d example.com -b duckduckgo

Competitive-intelligence value: public email patterns can indicate likely contact formats and help map public-facing departments. Do not use collected addresses for unsolicited messages, credential attacks, or impersonation.

3. Technology stack – Wappalyzer or BuiltWith

Tools: Wappalyzer browser extension or BuiltWith website lookup. These services infer publicly visible technologies such as content-management systems, analytics tools, JavaScript frameworks, and web-server products from a website's observable characteristics.

Competitive-intelligence value: the technology profile can help understand the company's digital services and likely platform choices. Detection can be incomplete or inaccurate, so findings should be verified against more than one public source.

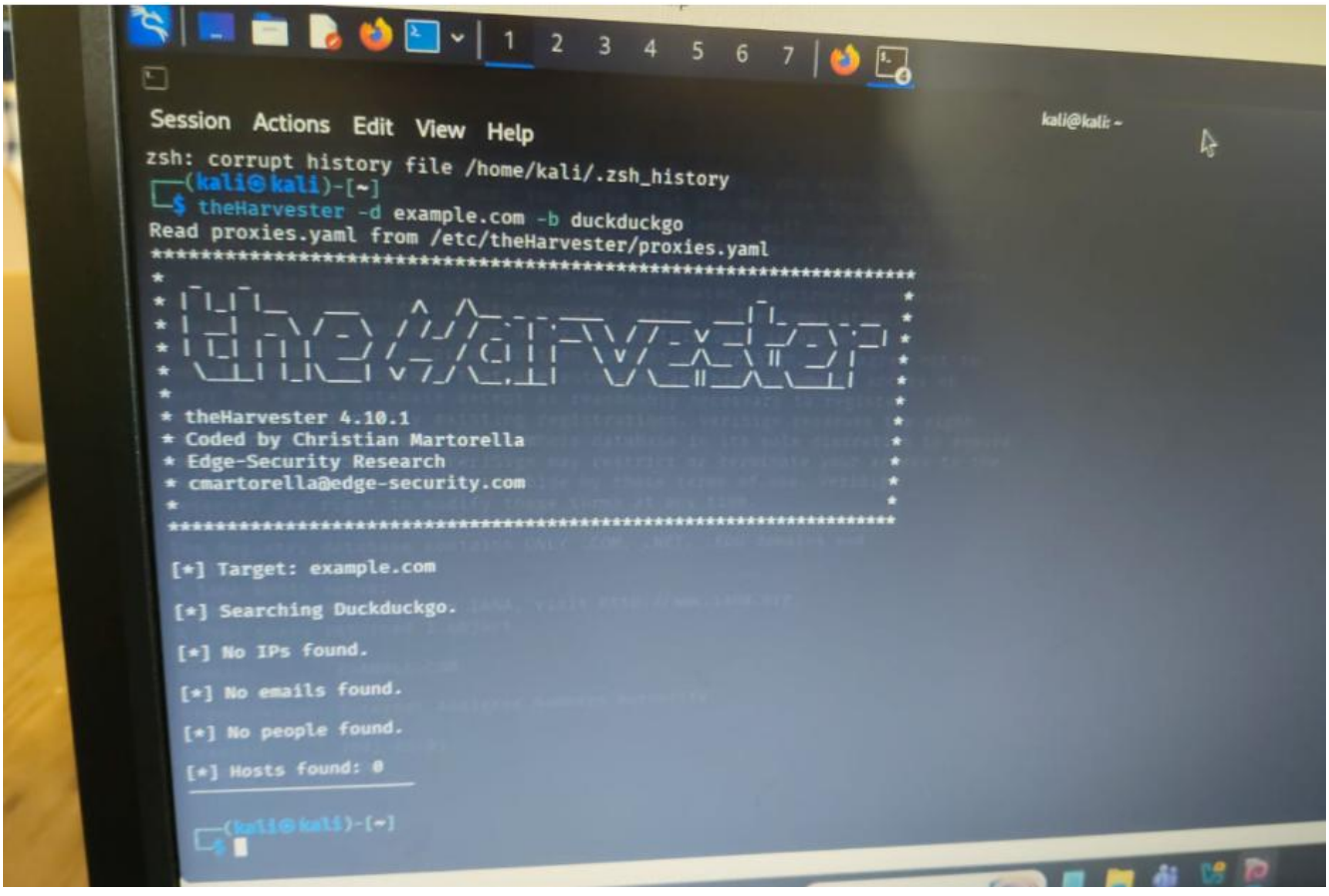
4. Publicly exposed subdomains – Certificate Transparency and passive DNS

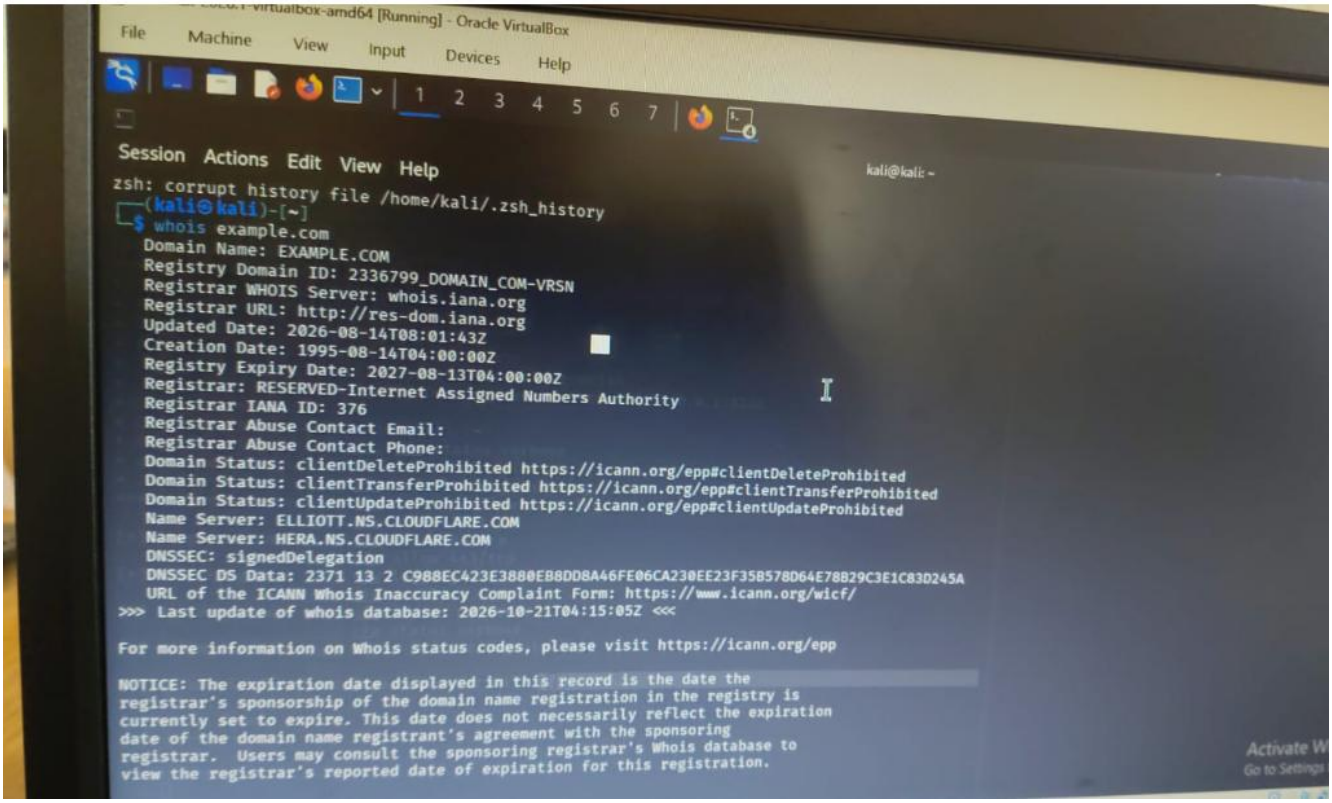
Tools: Certificate Transparency search services such as crt.sh, and passive DNS services. These sources can reveal subdomain names that have appeared in publicly logged TLS certificates or DNS observations, without actively probing the target's servers.

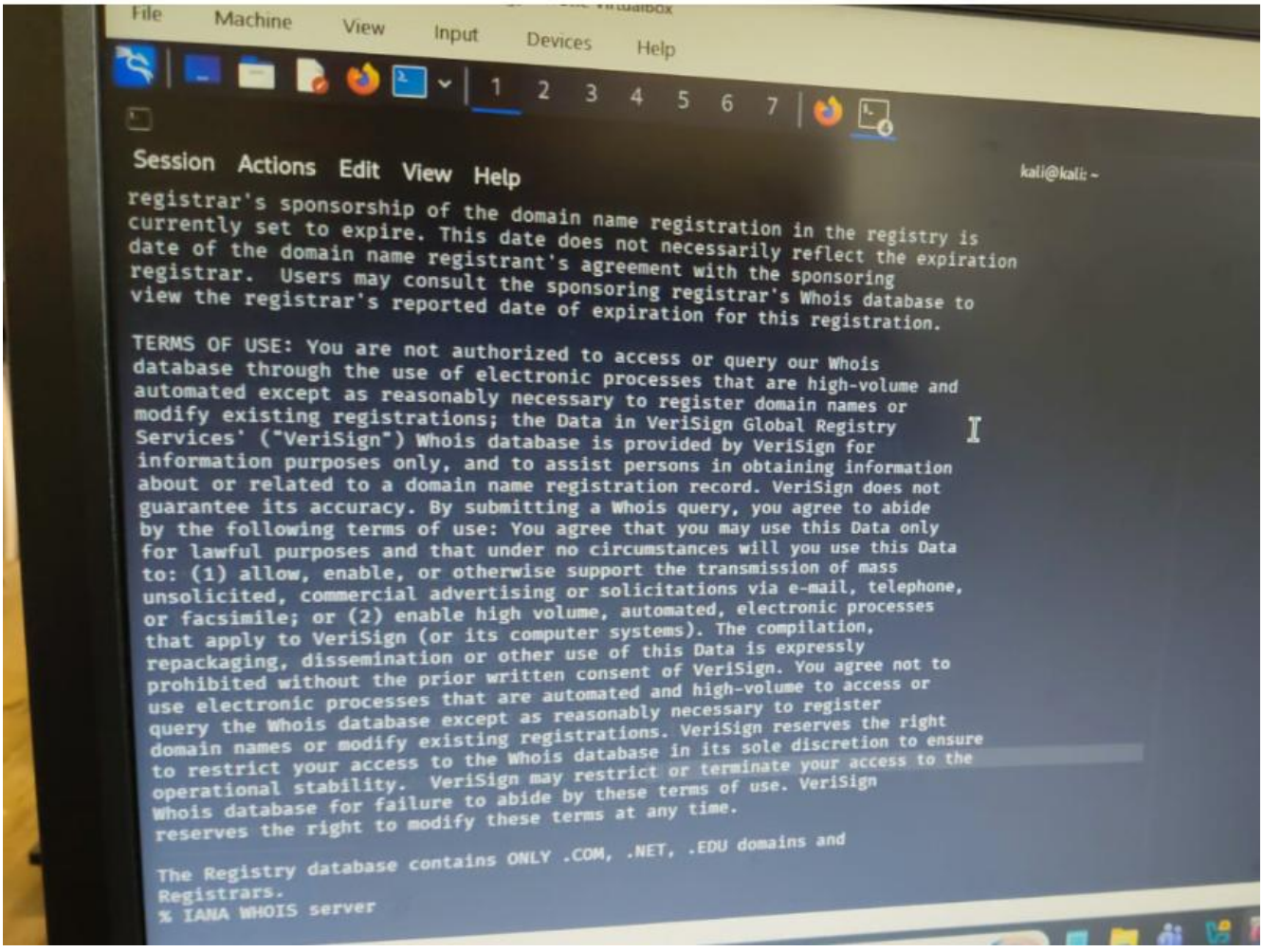
Example public lookup: search crt.sh for %.example.com in a browser.

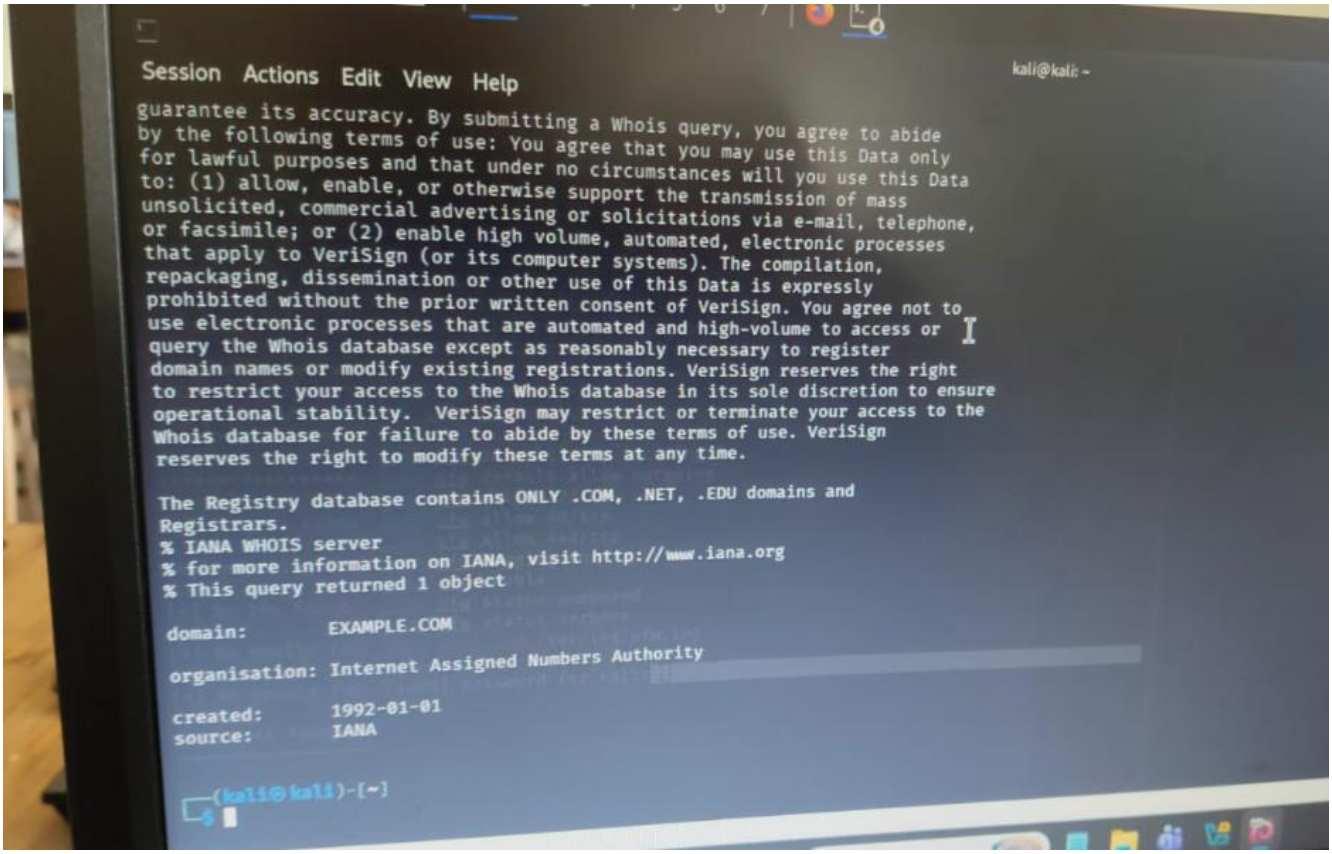
Competitive-intelligence value: subdomains may reveal public services, regional sites, development portals, or mail-related infrastructure. A discovered name does not prove that the host is currently active or exposed to the internet.

Results:




File Machine View Input Devices Help
Session Actions Edit View Help
kali@kali: ~
zsh: corrupt history file /home/kali/.zsh_history
(kali㉿kali)-[~]
$ whois example.com
Domain Name: EXAMPLE.COM
Registry Domain ID: 2336799_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.iana.org
Registrar URL: http://res-dom.iana.org
Updated Date: 2026-08-14T08:01:43Z
Creation Date: 1995-08-14T04:00:00Z
Registry Expiry Date: 2027-08-13T04:00:00Z
Registrar: RESERVED-Internet Assigned Numbers Authority
Registrar IANA ID: 376
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: ELLIOTT.NS.CLOUDFLARE.COM
Name Server: HERA.NS.CLOUDFLARE.COM
DNSSEC: signedDelegation
DNSSEC DS Data: 2371 13 2 C988EC423E3880E88DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D245A
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-10-21T04:15:05Z <<<
For more information on Whois status codes, please visit https://icann.org/epp
NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.


File Machine View Input Devices Help
Session Actions Edit View Help
kali@kali: ~
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.
TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to VeriSign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of VeriSign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. VeriSign reserves the right
to restrict your access to the Whois database in its sole discretion to ensure
operational stability. VeriSign may restrict or terminate your access to the
Whois database for failure to abide by these terms of use. VeriSign
reserves the right to modify these terms at any time.
The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
% IANA WHOIS server





Conclusion

WHOIS/RDAP, theHarvester, Wappalyzer/BuiltWith, and Certificate Transparency/passive DNS provide different views of a company's public footprint. Combining results can support competitive intelligence and help prioritize defensive review. Keep the work passive, follow the assessment scope, record sources and dates, and avoid accessing systems or data without authorization.

Q2. DNS Zone Transfers (15 Marks)

Scenario: During an authorized penetration test, the analyst suspects that a DNS server may permit an unauthorized zone transfer.

1. Identify the authoritative name server

Use a normal DNS query to identify the domain's name servers:

dig NS example.com

Choose an authoritative name server returned by the query. Replace example.com and ns1.example.com with the domain and name server explicitly included in the test scope.

2. Test for a zone transfer (AXFR)

Run this only against an in-scope domain and its authorized name server:

dig AXFR example.com @ns1.example.com

If the transfer is refused, times out, or returns a transfer failure, the server did not provide the zone through this test. A timeout alone does not prove that the configuration is secure; network filtering or connectivity issues may also explain it.

If the transfer succeeds, the output may contain many DNS resource records. Save the evidence securely and report only the minimum necessary details.

3. How returned DNS records assist reconnaissance

- **A / AAAA records:** Map hostnames to IPv4 / IPv6 addresses; these may identify public-facing systems.
- **MX records:** Identify mail exchangers and help map the organization's email infrastructure.
- **NS records:** List authoritative name servers for the zone.
- **CNAME records:** Show aliases that may point to other hostnames or hosted services.
- **TXT records:** May contain SPF, verification, or other domain-policy information; handle any sensitive-looking data carefully.
- **SRV records:** Can advertise the hostname and port of particular services.
- **Subdomain names:** Can reveal service names such as vpn, mail, portal, dev, or test; names alone do not prove a service is reachable.

4. Security impact and recommendations

An unrestricted zone transfer can disclose the organization's DNS inventory and make reconnaissance easier. The records do not automatically expose credentials or prove that internal hosts are reachable. The analyst should document the exact server, time, command, and result, then recommend restricting AXFR to approved secondary DNS servers, reviewing access-control lists and firewall rules, and monitoring DNS configuration changes.

Result:

```
┌──(kali㉿kali)-[~]
└─$ nslookup -type=NS example.com
Server:         172.21.100.31
Address:        172.21.100.31#53

Non-authoritative answer:
example.com     nameserver = hera.ns.cloudflare.com.
example.com     nameserver = elliott.ns.cloudflare.com.

Authoritative answers can be found from:
```

```
┌──(kali㉿kali)-[~]
└─$ dig @hera.ns.cloudflare.com example.com AXF

; <<>> DiG 9.20.20-1-Debian <<>> @hera.ns.cloudflare.com example.com AXF
; (6 servers found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 60440
;; flags: qr aa rd; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

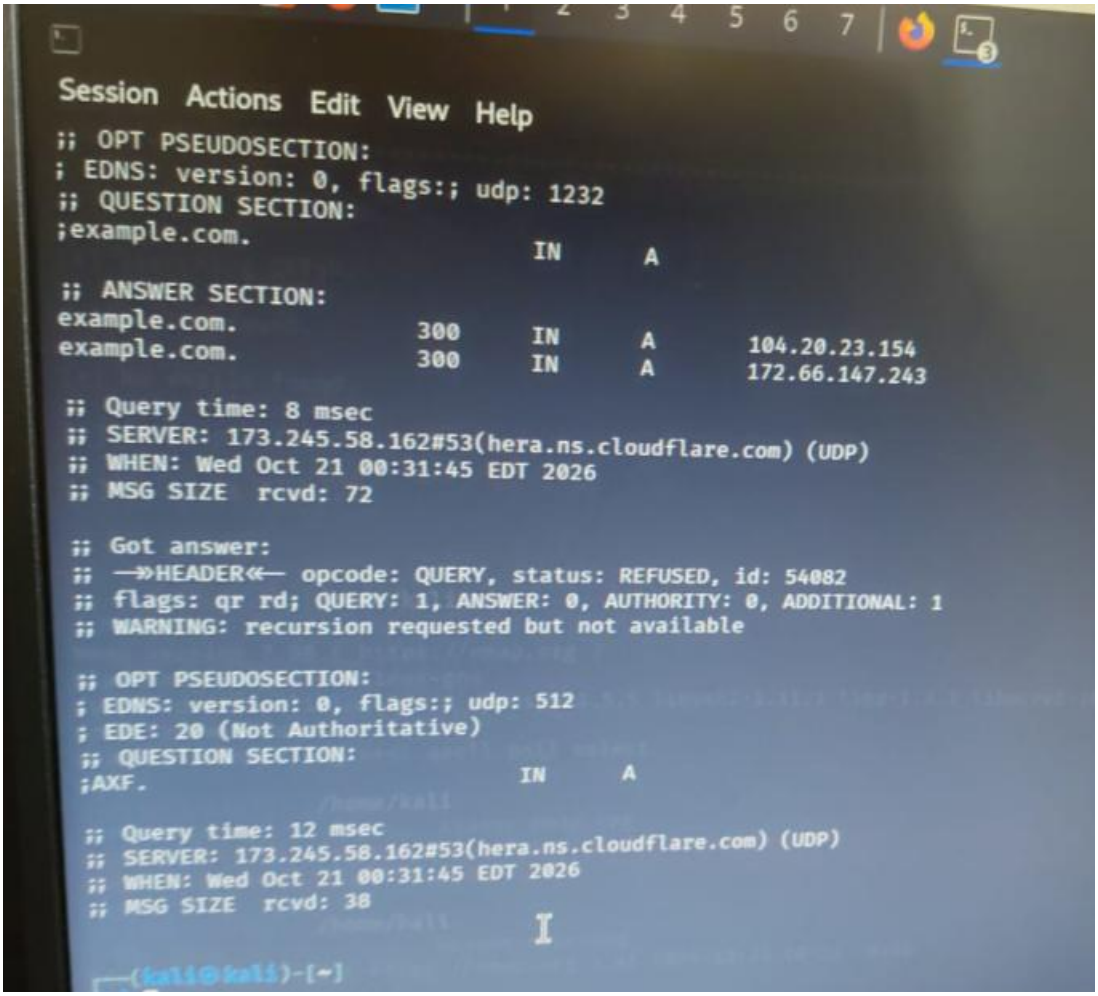
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;example.com.                   IN      A

;; ANSWER SECTION:
example.com.            300     IN      A       104.20.23.154
example.com.            300     IN      A       172.66.147.243

;; Query time: 8 msec
;; SERVER: 173.245.58.162#53(hera.ns.cloudflare.com) (UDP)
;; WHEN: Wed Oct 21 00:31:45 EDT 2026
;; MSG SIZE  rcvd: 72

;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: REFUSED, id: 54082
;; flags: qr rd; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
```



Conclusion

The dig NS command identifies authoritative name servers, and dig AXFR tests whether a permitted zone transfer is available. A successful transfer can disclose hostnames and mail/service infrastructure, so the finding should be reported responsibly and corrected by limiting transfers to trusted secondary servers.

Q3. Social Engineering – Phishing Email and Countermeasures (20 Marks)

Scenario shown in the question: Employees receive an email claiming to be from the IT department and asking them to verify their login credentials through a link because of an urgent security update.

1. Identify the attack

This is a phishing attack, specifically an impersonation or credential-harvesting attempt. The attacker pretends to be a trusted IT department, creates urgency, and directs employees to a link where they may be tricked into entering their username and password. The visible sender name and link text can be forged or made misleading.

2. Warning signs

- Urgent language that pressures the employee to act immediately.
- A request to enter or confirm a password through an email link.
- A sender address or domain that does not exactly match the organization's official domain.
- A link whose destination differs from the displayed text or leads to an unfamiliar website.
- Unexpected attachments, unusual grammar, or a message that bypasses the normal IT process.

3. Countermeasures for employees

1. Do not click the link, open unexpected attachments, or enter credentials from the email.
2. Verify the request through a known official channel, such as the company help desk or a bookmarked internal portal—not by replying to the suspicious email.
3. Report the message using the organization's phishing-report button or IT/security contact.
4. If a link was opened or credentials were entered, notify IT/security immediately; change the password through the official site and follow the incident-response instructions.
5. Do not forward the message to colleagues as a warning unless the security team's reporting procedure instructs you to do so.

4. Countermeasures for the organization

- Provide regular phishing-awareness training and simulated exercises.
- Deploy email filtering, anti-malware scanning, and URL/attachment analysis.
- Configure SPF, DKIM, and DMARC appropriately to reduce domain spoofing.
- Enable multi-factor authentication (MFA), preferably phishing-resistant MFA where practical.
- Use least-privilege access, strong password policies, and monitoring for suspicious sign-ins.
- Maintain a clear reporting process and an incident-response plan for suspected credential theft.

Conclusion

The email is likely a phishing attempt because it impersonates IT, uses urgency, and asks employees to verify credentials through a link. Employees should avoid interacting with the link, independently verify the request, and report it. Technical controls, MFA, and ongoing awareness training reduce the likelihood and impact of successful phishing.

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand